# 資安研究 101

08 April, 2026 at 新竹女中資訊研究社

# 黃俊嘉 Ice1187

- 奧義智慧科技 資安研究員
- 臺南一中資訊社 T19 副社長
- ACM CCS (poster), CyberSec, SEECON 講者
- 研究領域
  - AI 安全
  - 模糊測試
  - 惡意程式分析

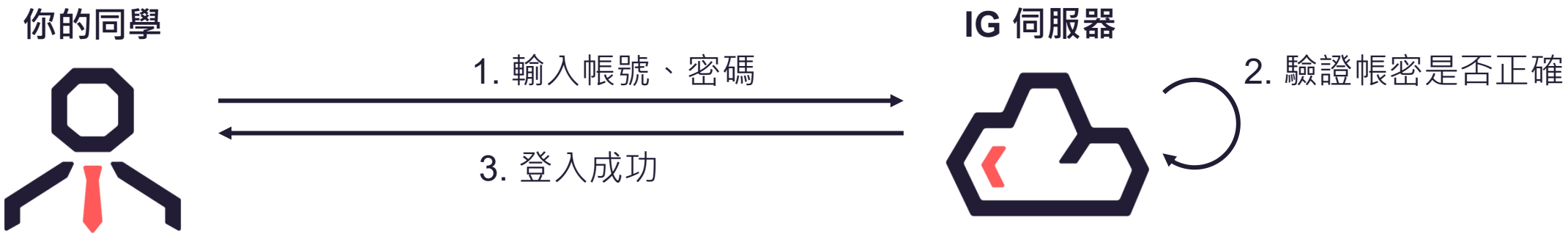
# 線上提問 Slido

- 歡迎任何問題
- Code: **3755170**
- https://slido.com/3755170

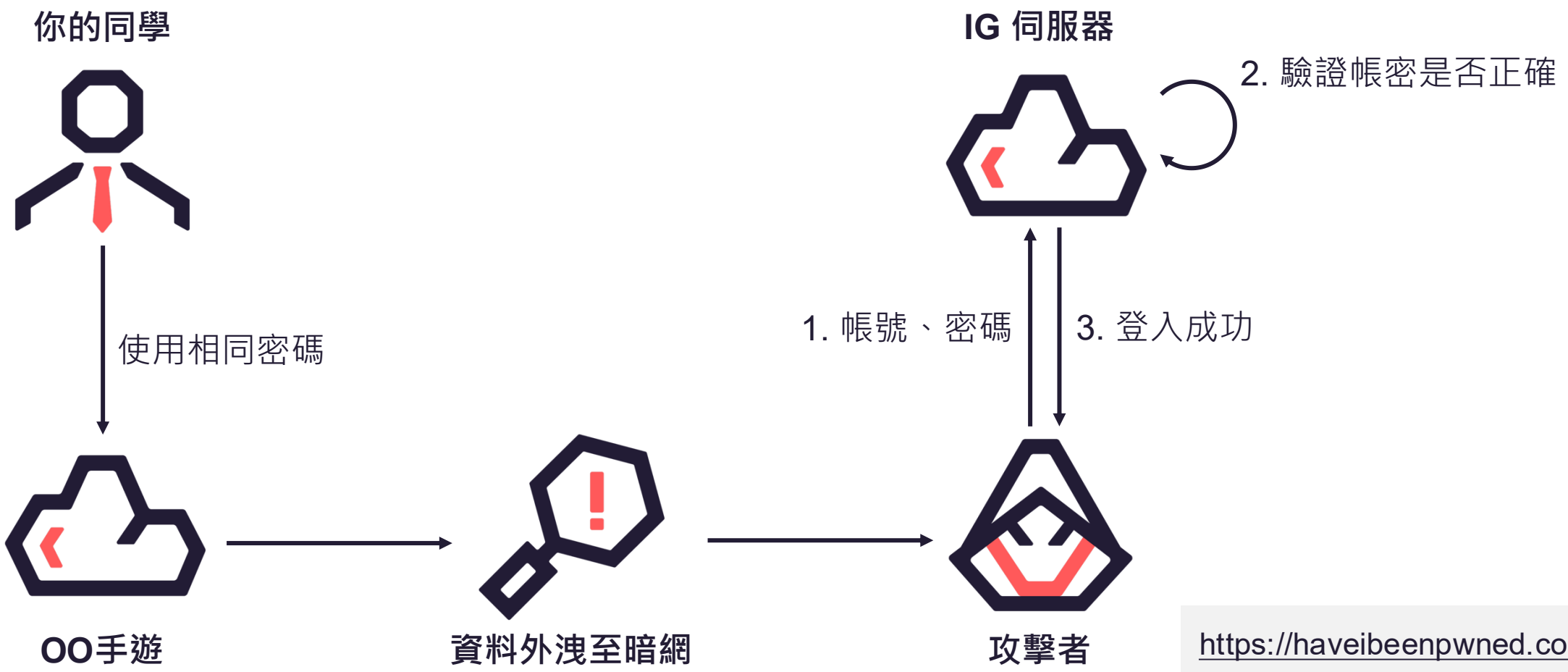
# 你要怎麼偷走你同學的 IG 帳號？

此提問與後續範例僅為促進聽眾參與，請勿進行未授權的非法攻擊

# 登入流程

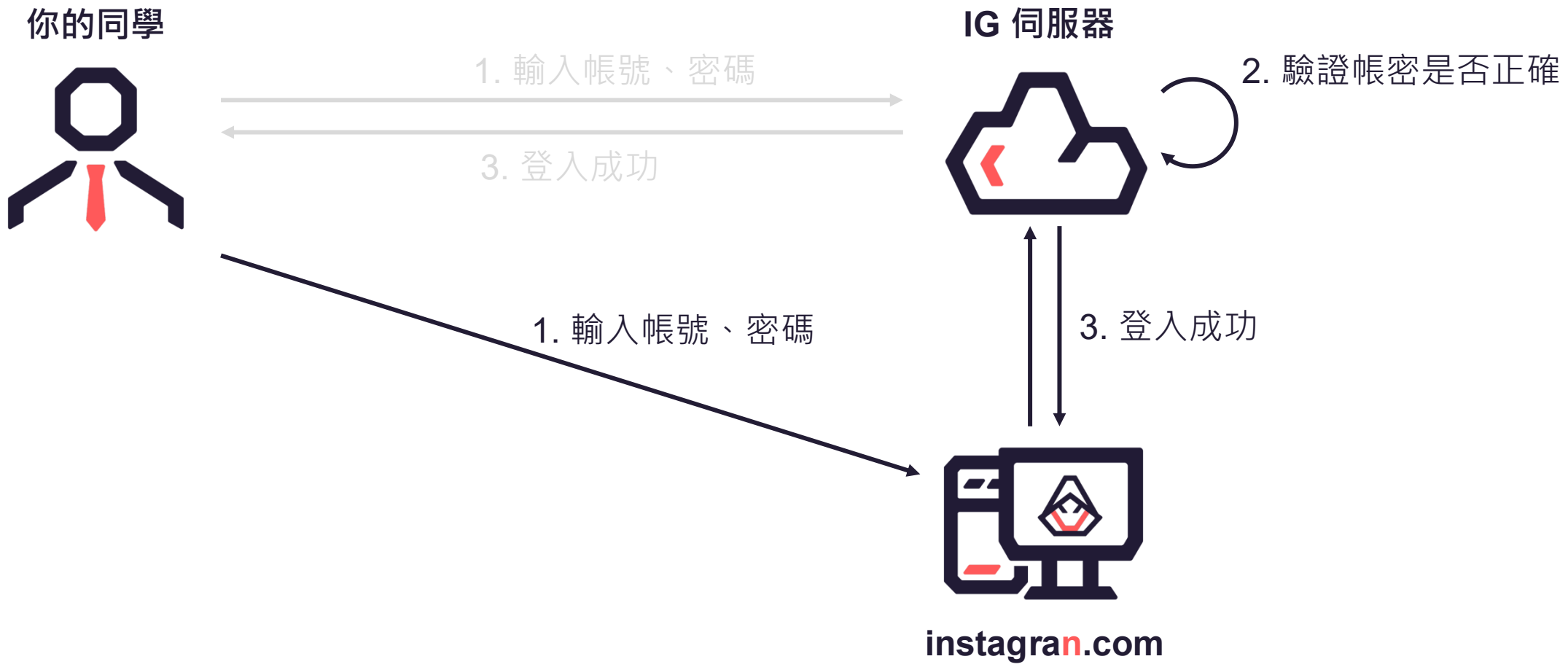


# 攻擊資料：撞庫攻擊

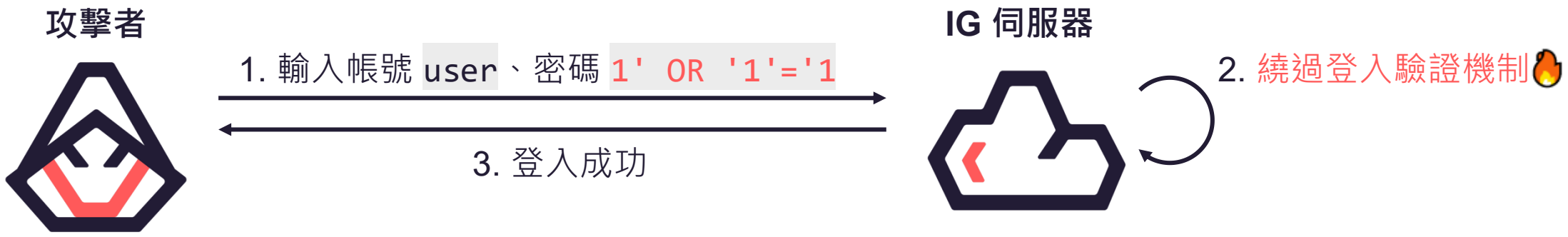



https://haveibeenpwned.com/

# 攻擊用戶：中間人攻擊


你的同學
IG 伺服器
1. 輸入帳號、密碼
3. 登入成功
2. 驗證帳密是否正確
1. 輸入帳號、密碼
3. 登入成功
instagran.com

# 攻擊服務：SQL 注入攻擊




🍊滲透 Facebook 的思路與發現

# 資安研究在做什麼？

- 深入了解系統運作
- 掌握漏洞成因與原理

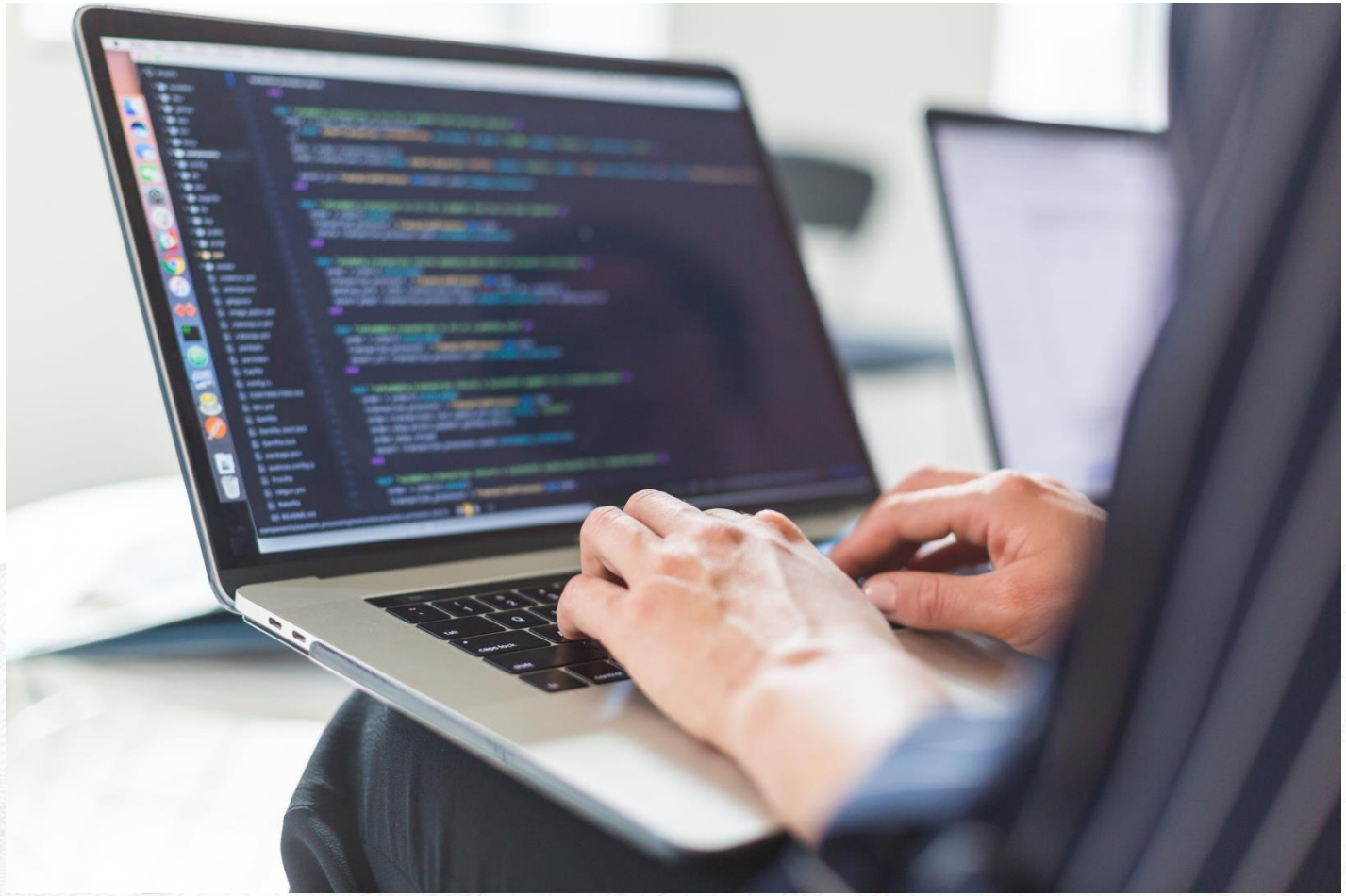


Photo by Matthew Henry from Burst

挖掘和攻擊

偵測和修補

# 漏洞

# 究竟什麼是漏洞？

> 外送點餐單上哪裡有問題？

外送

免洗餐具：是

顧客備註：

1 x 薯餅蛋吐司 Toast 50TWD

1 x 火腿三明治套餐 100TWD
Ham Sandwich Set
飲料選擇 DRINK CH 50TWD
1 x 紅茶 Black Tea --
選擇 CHOICES
1 x 冰 Ice --

顧客備註：
「不要加醬」

2 x 荷包蛋 Over Egg 30TWD
荷包蛋選擇 CHOICE OVER EGG
2x 半熟 Over Medium Egg --

1 x 熱狗 Hot Dog 30TWD
口味選擇 FLAVOR CHOICE
1x 原味 Original --

小計 160TWD
已付金額 160TWD

感謝您向 Restaurant 訂購美食

Image Source: https://www.uber.com/zh-TW/blog/merchant-printerconnect/

# 漏洞範例：外送單注入

- 未能區分「**系統指令**」與「**外部資料**」
- 程式中也會出現同樣的問題

外送

免洗餐具：是

顧客備註：
1 x 薯餅蛋吐司 Toast 50TWD

1 x 火腿三明治套餐 100TWD
Ham Sandwich Set
飲料選擇 DRINK CH 50TWD
1 x 紅茶 Black Tea --
選擇 CHOICES
1 x 冰 Ice --

顧客備註：
「不要加醬」

2 x 荷包蛋 Over Egg 30TWD
荷包蛋選擇 CHOICE OVER EGG
2x 半熟 Over Medium Egg --

1 x 熱狗 Hot Dog 30TWD
口味選擇 FLAVOR CHOICE
1x 原味 Original --

小計 160TWD
已付金額 160TWD

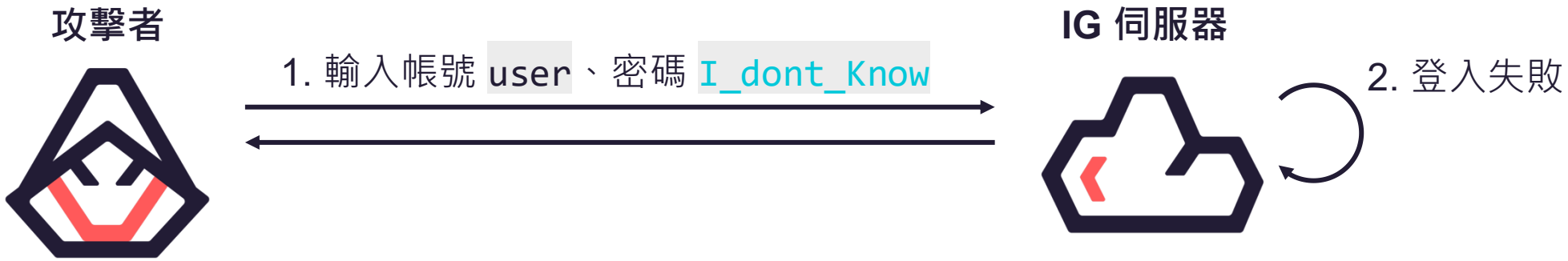
感謝您向 Restaurant 訂購美食

Image Source: https://www.uber.com/zh-TW/blog/merchant-printerconnect/

# SQL 漏洞導致的無密碼登入

登入驗證機制

```
SELECT * FROM users WHERE (name='user') AND (pw='I_dont_Know')
```



# SQL 漏洞導致的無密碼登入

登入驗證機制

```
SELECT * FROM users WHERE (name='user') AND (pw='I_dont_Know')
```

攻擊

```
SELECT * FROM users WHERE (name='user') AND (pw='1' OR '1'='1')
```

↓

```
SELECT * FROM users WHERE (name='user') AND True
```

↓

```
SELECT * FROM users WHERE (name='user')
```



CYCRAFT

# 資安研究的內容，離不開漏洞

## 紅隊 尋找新的系統漏洞與攻擊手法

- 漏洞挖掘與利用
- 滲透工具開發
- AI 越獄
- 紅隊演練 & 滲透測試
- 內網橫向移動
- 自動化攻擊模擬

## 藍隊 偵測與防禦攻擊，及清除威脅

- 漏洞掃描與修補
- 惡意程式分析
- AI 越獄偵測與防護
- 事件應變與調查
- 內網攻擊路徑盤點
- 駭客組織與情資追蹤

# 攻擊與防禦是一體兩面

| 紅隊 尋找新的系統漏洞與攻擊手法 | 藍隊 偵測與防禦攻擊，及清除威脅 |
| --- | --- |
| 漏洞挖掘與利用 | 漏洞掃描與修補 |
| 滲透工具開發 | 惡意程式分析 |
| AI 越獄 | AI 越獄偵測與防護 |
| 紅隊演練 & 滲透測試 | 事件應變與調查 |
| 內網橫向移動 | 內網攻擊路徑盤點 |
| 自動化攻擊模擬 | 駭客組織與情資追蹤 |

## 如何入門資安？ ⇒ 從攻擊開始（找漏洞、打漏洞）

（後半場會更深入討論）

# 學習方式

- 打 CTF
- 組讀書會
- 專題研究
- 自主學習
- 遊戲外掛
- 二轉
- ...

# 自學教材

- 台灣選手做的中文線上課程簡報 + 錄影 + 練習題
  - 軟體漏洞 Pwn：台大 計算機安全
  - 網頁攻擊 Web：How to Hack Websites, PortSwigger Academy
  - 逆向分析 Reverse：交大 程式安全
  - 密碼破解 Crypto：Crypto Course
- SCIST 資安課程社課影片

台灣資安 / CTF 學習資源整理



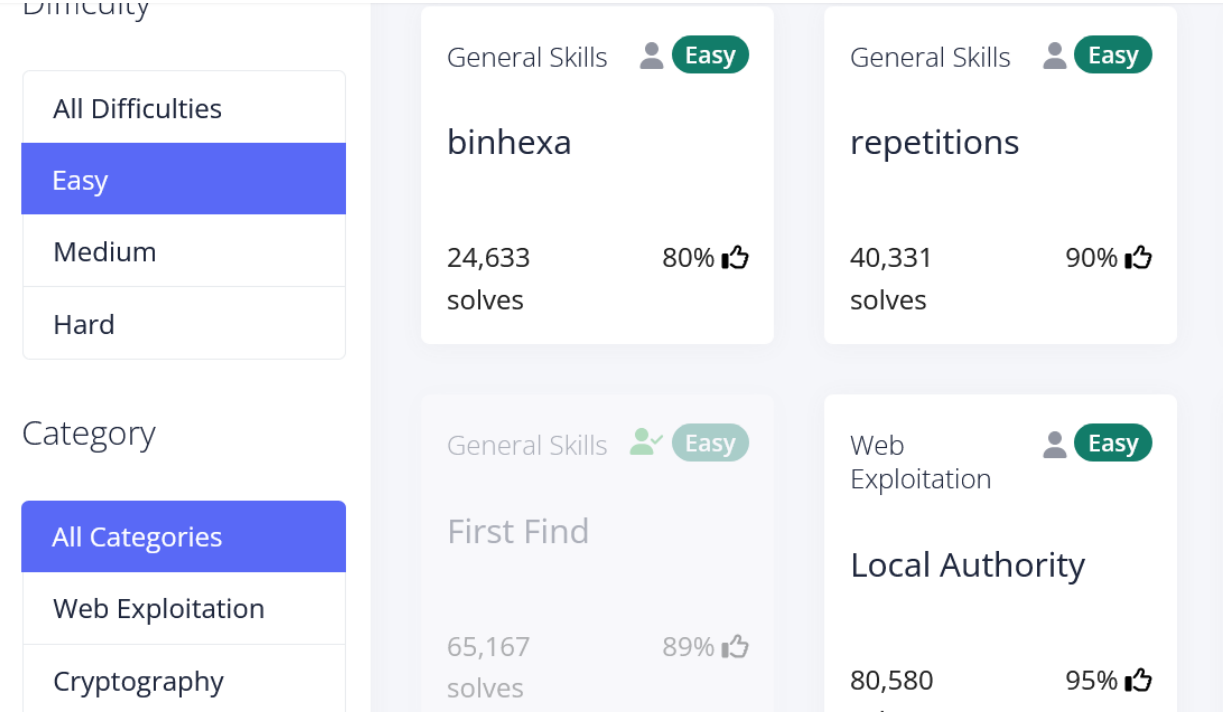
CYCRAFT

# 組讀書會

- 準備教材能有效發現自己學習的盲點
- 累積學習歷程 / 推甄 / 履歷
- **執行上的重點**
  - 選自己有興趣的主題
  - 教學而非分享
  - 時長不宜過長
    - 40 mins + 10 mins QA

# 打 CTF

- CTF 是資安領域競賽的統稱
- 實際練習技術，並看見進步
- 爬 rank，跟**全世界的人卷排名**

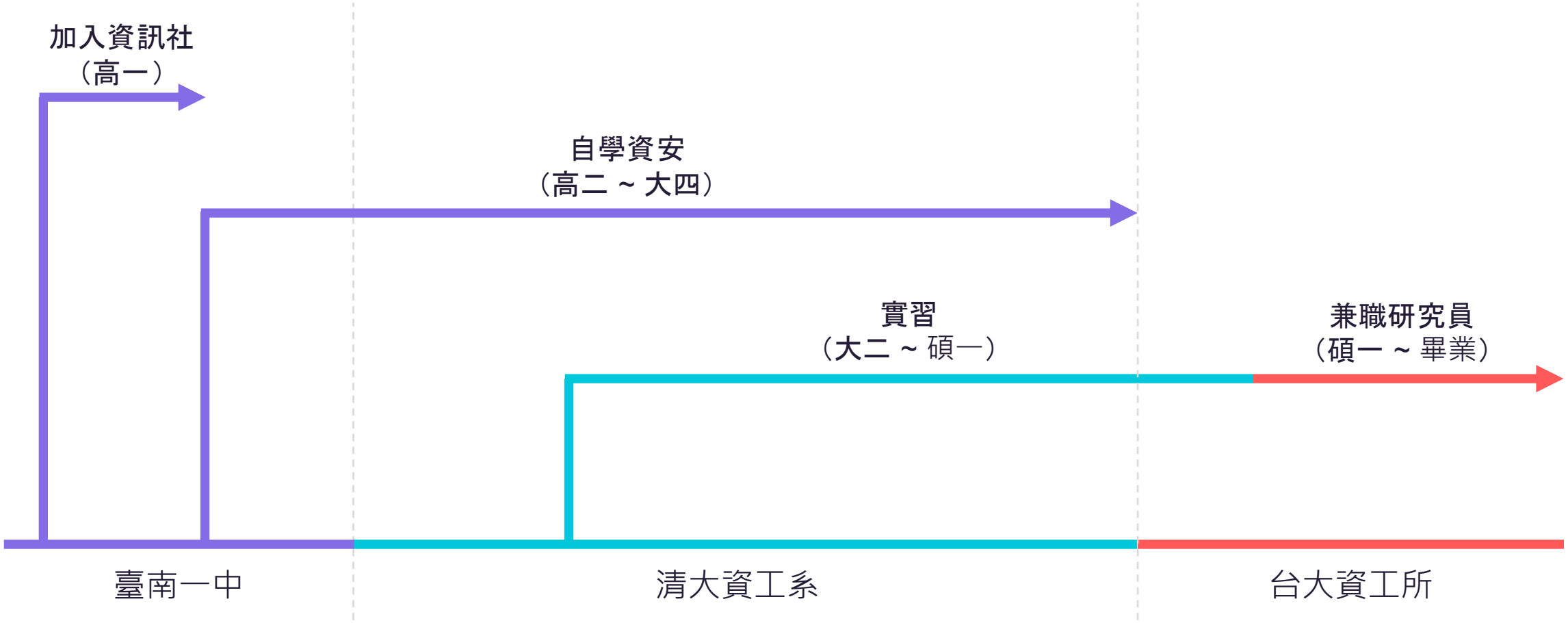



https://picoctf.org/

# 相同方法也適用於其他領域

- 自行研究、練習題目、組讀書會
  - 競程：Codeforces, AtCoder
  - 演算法：LeetCode
  - ML：Koggle
- **如果有興趣可以早點開始，並持之以恆**

# 我的學習歷程



# 變厲害的方法

- 1. 設定目標
- 2. 留下紀錄
- 3. 檢討
- 4. 花時間

# 1. 設定目標

- **目標越小越好**，重點是能做到
  - 每週解一道題目
  - 每月看一部教學影片
  - 每天看一頁原文課本
- 長期累積 > 短時間衝刺

# 2. 留下紀錄

- 升學、求職非常需要
  - 高中 – 學習歷程 / 推甄 / 繁星
  - 大學 – 碩士推甄 / 實習 / 求職
- 緩解自卑與焦慮

# 3. 檢討

- 檢討錯誤才知道自己錯在哪
  - 考卷寫錯的題目沒檢討，下次還是不會！
- **進步最快的方法**

# 4. 花時間

- 花越多時間，就會有越多進步
- 每個人都有自己的取捨
  - 課業
  - 社團
  - 手遊
  - 動漫
  - 戀愛
  - 睡覺

# 面對自卑與冒牌者症候群

- 繼續在資訊領域深耕，非常有可能在某個時刻遇到
- 緩解方法
  - 留下紀錄（大腦很容易忽略自己所做過的努力，並放大他人的成就）
  - 設定目標（達成目標，證明自己在持續成長）
  - 放下比較（時間分配與生活平衡）

冒牌者症候群（Imposter Syndrome）是一種心理現象，指個人即使有明顯的成就，卻仍覺得自己不夠格，擔心被揭穿其實是「冒牌貨」，而不相信自己的能力和努力。

# 台灣資安 / CTF 學習資源整理

- 線上課程
- CTF 競賽、練習平台
- 營隊與培訓計畫
- 實習、贊助

README MIT license

## Basics

- 高中職生資安研習營
- AIS3 Junior 新型態高中職資安課程
- Introduction to CTF by Ice1187
- Linux Basic by Ice1187
- 清大開放式課程 - 作業系統
- CSOs 數位防禦手冊 by OCF

## Pwn

- NTU Computer Security by Yuawn
- 2021 交大程式安全 binary exploit 課程教材 by u1f383 & kia
- 漏洞攻擊從入門到放棄 by frozenkp
- Linux Kernel Exploitation by Yuawn
- Angel Boy's SlideShares (YouTube Live Recording)
- Kazma's Blog
- u1f383's Blog

## Web

- How to Hack Websites by Splitline
- [資安新手入門手冊] Web Security 領航之路 by 飛飛
- Huli's Blog
- Beyond XSS：探索網頁前端資安宇宙 by Huli
- Orange 🍊 's Blog

## 營隊 & 培訓計畫

- ~~高中職生資安研習營~~ (此子計畫已結束)
- AIS3 Junior 新型態高中職資安課程
- AIS3 新型態資安實務主題課程
- 臺灣好厲駭 高階資安人才培訓計畫
- 南臺灣學生資訊社群 SCIST 資訊安全課程
- 中部高中電資聯合會議 SCAICT 資訊安全課程
- TeamT5 Security Camp 資安培訓營
- Global Cybersecurity Camp (GCC)
- TDOH - 資安功德院
- 國家資通安全研究院 培訓課程
- HITCON Training

## 社群 & 學校社團

- Deep Hacking 讀書會
- 南臺灣學生資訊社群 SCIST (FB 粉專) (YouTube)
- 中部高中電資聯合會議 SCAICT
- CURA (CyberSecurity Unions Research Association)
- HITCON GIRLS (女性 only)
- TDOHacker
- UCCU Hacker
- CHROOT
- B33F 50UP
- StarHack 星駭資安社群 (public Discord)

https://github.com/Ice1187/TW-Security-and-CTF-Resource



CYCRAFT

# Q&A

Thanks for your participation.

資安學習資源

回饋表單